Understanding Web Security: An Introduction to OWASP and Cryptographic Risks

By : Raimihakim, Irfan Haziq, Sufi Aqlisya
Lecturer : Mr.Khairul Amin

1. Introduction to OWASP

1.1 Overview and Importance of OWASP

OWASP (Open Worldwide Application Security Project) is a non-profit organization that focuses on improving software and web application security. It provides free resources, tools, and guidelines to help developers identify and prevent security vulnerabilities. OWASP is important because it helps organizations protect sensitive information, reduce security risks, and develop more secure applications.

1.2 The OWASP Top 10

The OWASP Top 10 is a list of the most critical security risks in web applications. It helps developers and organizations understand common vulnerabilities, such as Broken Access Control, Injection, and Cryptographic Failures. By following this list, organizations can identify potential weaknesses, improve security practices, and protect their applications from cyberattacks.

1.3 Update Frequency and Reasons for Change

The OWASP Top 10 is updated periodically, usually every few years, based on new security research, industry data, and emerging threats. The latest version is OWASP Top 10: 2025. Updates are necessary because cyber threats and technologies continue to change. The updates help organizations stay aware of current security risks and apply suitable prevention methods.

2. OWASP Risk Analysis

Risk: Cryptographic Failures

2.1 Risk Description

This occurs when an application or system uses outdated or weak cryptographic algorithms, increasing the chance of key exposure and placing sensitive data in a vulnerable state.

2.2 How It Happens

Databases using simple and unsalted hashes to store user credentials. It increased the chance for an attacker to figure out the credentials by using rainbow tables or pre-calculated hashes.Furthermore, simple fast hash functions (such as MD5 or SHA-1) can easily be brute-forced using modern GPUs, even when salted. .

2.3 Prevention

Ensure cryptography standards are kept up to date by avoiding algorithms known to be weak or compromised. Passwords should be stored using memory-hard function, delayed hashing functions such as **Argon2**, **scrypt**, or **bcrypt**.

3. Real-World Case Study

Case Study Focus: LastPass Data Breach

3.1 Breach Incident Summary

LastPass is a company that helps users store their passwords securely. In 2022, the company experienced a security breach that happened in two stages. First, an attacker gained access to a developer's computer and stole some company information. Later, the attacker used information from the first incident to target another employee and access cloud storage containing customer backups.

According to LastPass's report published in March 2023, the attacker managed to obtain copies of customer vault data and other sensitive information. Although the password vaults were encrypted, the stolen data could still be at risk if users had weak master passwords. An attacker could try to guess these passwords offline to access the information stored inside the vaults.

3.2 Correlation to OWASP Risk

This incident is related to **OWASP Top 10:2025 A04 – Cryptographic Failures** because it involved the exposure of sensitive data that relied on encryption for protection.

Even though LastPass used encryption to protect customer vaults, the breach showed that encryption alone is not enough if other security measures are weak. For example, users with weak master passwords could face a higher risk because attackers might try to guess their passwords and decrypt their stolen vault data.

However, this incident was not caused by a confirmed use of unsalted password hashes. Instead, it highlights the importance of strong encryption, proper key management, and protecting sensitive data from unauthorized access.

3.3 Prevention Analysis

There are several ways to reduce the risk of similar incidents. First, companies should use strong and up-to-date encryption methods to protect sensitive information. They should also ensure that encryption keys and other secrets are stored securely and cannot be easily accessed by attackers.

Second, users should be encouraged to create strong and unique master passwords. This makes it harder for attackers to guess passwords and access encrypted data.

Companies should also protect employee accounts by using multi-factor authentication and limiting access to sensitive systems. Regular security checks and monitoring can help detect suspicious activities before they cause more damage.

4. References

https://top10.owasp.org/2025/A04_2025-Cryptographic_Failures/#how-to-prevent

https://www.cloudflare.com/learning/security/threats/owasp-top-10/

https://tracexlabs.com/knowledge-base/cryptographic-failures-types-causes-and-prevention.html

https://top10.owasp.org/2025/

https://top10.owasp.org/2025/A04_2025-Cryptographic_Failures/

https://blog.lastpass.com/posts/security-incident-update-recommended-actions

https://blog.lastpass.com/posts/notice-of-recent-security-incident